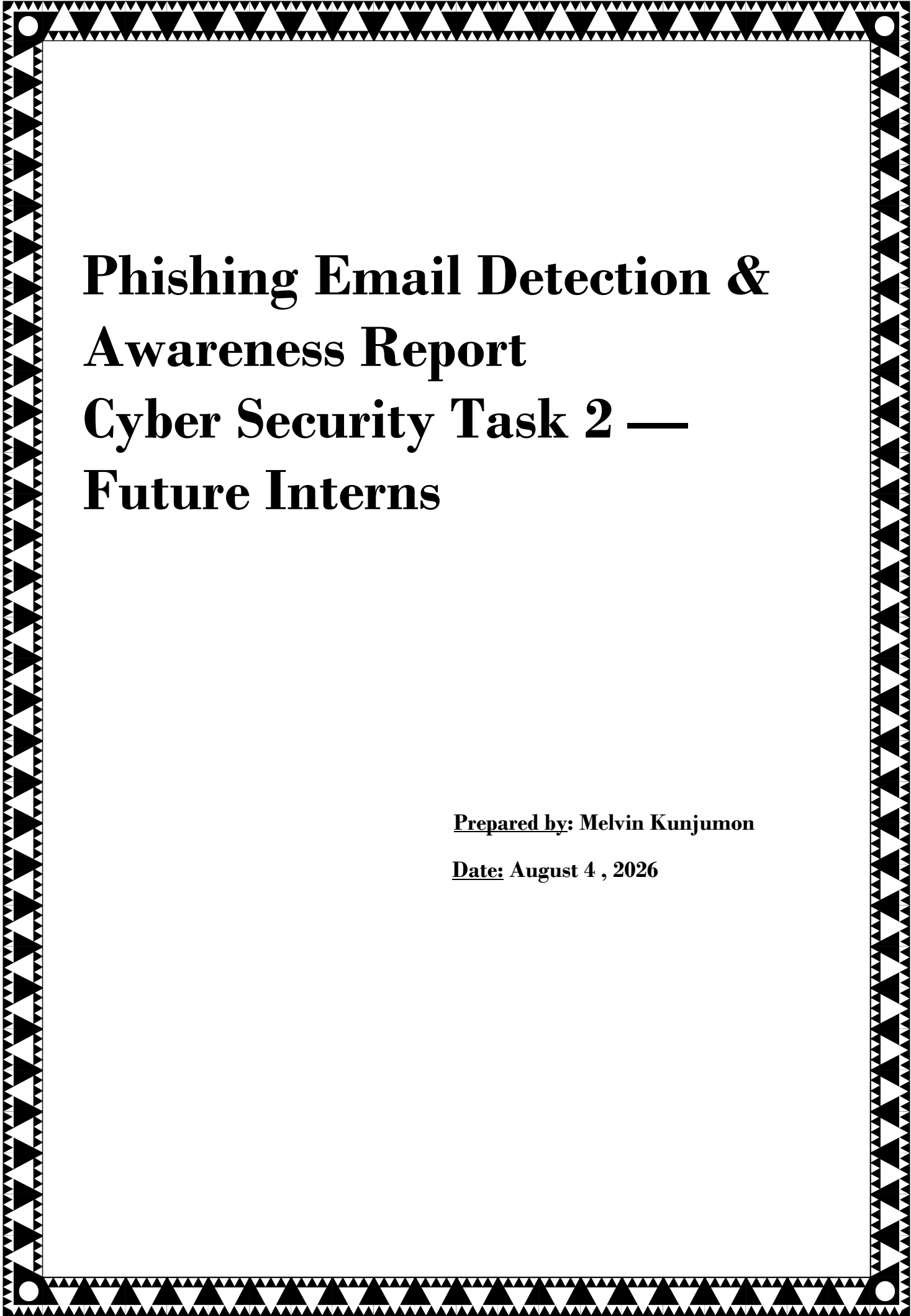




Phishing Email Detection & Awareness Report Cyber Security Task 2 — Future Interns

Prepared by: Melvin Kunjumon

Date: August 4 , 2026

#1. Executive Summary

This report presents a phishing email detection and awareness analysis conducted as part of the Cyber Security Internship program at Future Interns. Seven real-world phishing email samples were collected from a public, actively maintained phishing archive and analyzed for common indicators of fraud, including sender authentication failures, domain mismatches, suspicious links, and psychological manipulation tactics such as urgency and impersonation of trusted brands.

Each email was examined at the header level (sender authentication, originating server, reply-to address) and at the content level (subject line framing, body text, embedded links) to identify red flags a typical user could realistically learn to recognize. All seven samples were classified as Phishing, spanning several distinct attack types: brand impersonation, advance-fee scams, prize/reward scams, disguised-link spam, and a cryptocurrency airdrop scam.

The goal of this report is not only to document these findings, but to translate technical indicators into plain-language guidance that non-technical users — such as employees without a security background can apply to protect themselves from similar attacks in daily email use.

#2. Methodology

Email samples were sourced from a public, continuously updated phishing archive (rf-peixoto/phishing_pot on GitHub), which collects real phishing emails for research and educational purposes. Seven samples were selected to represent a range of distinct attack patterns rather than near-duplicate examples.

For each sample, the following analysis steps were performed:

- 1. Header Analysis** — The email's raw header was examined for the Authentication-Results field, which reports the outcome of three industry-standard checks: SPF (verifies the sending server is authorized for that domain), DKIM (verifies the message wasn't altered in transit via a cryptographic signature), and DMARC (combines both checks into an overall policy decision). A failure in any of these is a strong technical indicator that a sender's identity could not be verified.
- 2. Origin Verification** — The header's "Received: from" chain was traced to identify the true originating mail server, and compared against the domain the email claimed to be from (e.g. a message claiming to be from a bank but originating from a generic cloud server or an unrelated third-party domain).
- 3. Reply-To Comparison** — The Reply-To address was checked against the From address. A mismatch — particularly to a free webmail account (e.g. Gmail) — is a common indicator of a spoofed or impersonated sender, since legitimate organizations rarely route replies to personal email accounts.
- 4. Content and Link Review** — Each email's subject line and body were reviewed for urgency-based language, emotional manipulation, unrealistic offers, and generic greetings. Any links present were inspected (without being clicked) to check whether their destination domain matched the sender's claimed identity.

No emails were opened in a live mail client, no links were clicked, and no attachments were downloaded at any point during this analysis, in line with safe handling practices for phishing samples.

#3. Findings

1. Email: sample-1011.eml

- **Claims to be from:** "Stephanie C. Frisbie"
<samranefahim@gmail.com> — sent through a spam mailing list (monkey56.skin) disguised as a Google Group
- **Actually sent from:** Legit Gmail infrastructure (SPF/DKIM/DMARC all technically pass for gmail.com) — but relayed through a spam distribution list at "monkey56.skin," a disposable-looking domain
- **Red flags:**
 - Subject line is a health-product ad with excessive underscores/caps formatting ("_Get_Rid_of_Back_Pain_Easily.Try_Therapal!_") — classic spam styling
 - No real message body — the entire email is just two tinyurl.com shortened links wrapped around images, nothing else
 - Shortened URLs (tinyurl.com) deliberately hide the real destination — a major red flag since you can't see where you'd actually land before clicking
 - Sent via a disposable-sounding mailing list domain (monkey56.skin) designed to distribute spam/scam content at scale, not a real business
- **Classification:**
Phishing (specifically: malicious/scam spam — likely leads to a fake product page or further scam, using shortened links to disguise the destination)

2. Email: sample-1012.eml

- **Claims to be from:** "Global Merit Expert" (loan services) — Mr Richard Owen
- **Actually sent from:** shore@suksapan.or.th, relayed through the same compromised Thai mail server (host4.ns.co.th) seen in sample-1013 — different scam content, identical delivery infrastructure
- **Red flags:**

- From address (shore@suksapan.or.th) has nothing to do with a loan company called "Global Merit Expert"
- Reply-To mismatch: replies go to globalmeritexperts@gmail.com, a free Gmail account, not a real company domain — no legitimate lender would operate exclusively through Gmail
- Authentication failed: SPF softfail, DKIM none, DMARC none
- Unsolicited loan offer with no application process, credit check, or verification mentioned — just "contact us," a classic advance-fee loan scam setup
- Generic greeting ("Hello"), no recipient name, sent in bulk
 - **Classification:**
Phishing (advance-fee loan scam)

3. Email: sample-1017.eml

- **Claims to be from:**
Otto.de (a real, well-known German retail company)
- sender name shows "otto-newsletter@newsletter.otto.de"
- **Actually sent from:** winner-win.art, a completely unrelated domain
—
the "otto.de" appearance is entirely fake, created by manipulating the display name field
- **Red flags:**
 - Authentication failed: SPF softfail, DKIM none, DMARC fail — the system explicitly could not verify the sender despite it displaying "Otto.de" branding
 - Reply-To goes to reply_to@winner-win.art — completely unrelated to Otto or any legitimate retailer
 - Sending server hostname is a random alphanumeric string ("qktxfxthukmwfnksijbkrjxkzhstbswa.whstr8") — not a real corporate mail server
 - Subject line uses excessive emojis and exaggerated claims ("Individual forecast for rapid weight loss") — classic too-good-to-be-true product scam styling
 - Body promotes an unrelated diet product ("KetoXplode") with urgency language ("Hurry! Limited stock until June") and fake countdown-style pressure — has nothing to do with Otto.de as a retailer
 - Links route through a suspicious tracking/redirect domain (firiri.shop) rather than any legitimate retailer domain

➤ **Classification:**

Phishing (brand impersonation used to push an unrelated scam product — a "malvertising" style attack)

4.Email: sample-1020.eml

➤ **Claims to be from:** Costco (a real, well-known retailer) — sender name

"Costco Customer Support <noreply@costco.com>"

➤ **Actually sent from:** pcvelocity.com — completely unrelated to Costco

➤ **Red flags:**

- Authentication failed: spf=none, dkim=none, dmarc=fail — Costco's real domain would never fail these checks
- Return-Path shows a random address at oqmhwr.net — a throwaway-looking domain, not Costco
- Subject line uses fake urgency and false familiarity: "3nd attempt: You Are Our July Winner" (note the typo "3nd" instead of "3rd" — a strong tell of a low-effort mass scam)
- Classic "you've won a free gift" bait (nonstick cookware set) with no prior entry or relationship mentioned
- All links route through thebandalistry.com, a redirect/tracking domain entirely unrelated to Costco
- Fake urgency: "This Reward Offer Expires On Aug 9, 2023"

➤ **Classification:**

Phishing (prize/reward scam impersonating a trusted retail brand).

5.Email: sample-1059.eml

➤ **Claims to be from:** "Tether.to" (a real cryptocurrency company) — subject: "INVITE: Tether Gold [Airdrop]"

➤ **Actually sent from:** c.bakou.kossi@autodoc.de — autodoc.de is a real

German auto-parts retailer, completely unrelated to Tether or crypto. The attacker appears to be using a compromised or abused mail server belonging to a legitimate, unrelated company.

➤ **Red flags:**

- SPF and DMARC technically PASS (because the email really was sent through autodoc.de's real mail infrastructure) — but DKIM FAILS ("signature did not verify"), meaning the message content doesn't

match what autodoc.de's server actually signed. This is a key teaching point: passing SPF/DMARC doesn't guarantee safety if the sending domain itself has been compromised or abused.

- Reply-To is spoofed to display as "The Google Workspace Team" <workspace-noreply@google.com> — an attempt to borrow Google's trust, unrelated to both autodoc.de and Tether
- "Client ID" and airdrop framing designed to look like a personalized, legitimate crypto reward
- "CLAIM NOW" link routes through a Google Docs "drawings" URL — abusing a trusted domain (docs.google.com) to host a redirect, since security filters are less likely to flag a Google-owned link
- Sent to "Undisclosed recipients" — confirming mass distribution, not a personal invite

➤ **Classification:**

Phishing (cryptocurrency airdrop scam, using a compromised legitimate mail server and abusing Google Docs to disguise the malicious link)

6.Email: sample-1.eml

- **Claims to be from:** BANCO DO BRADESCO LIVELO (a real Brazilian bank) —

sender name "BANCO DO BRADESCO LIVELO"

- **Actually sent from:** banco.bradesco@atendimento.com.br — a generic-

sounding domain, not Bradesco's real corporate domain, ultimately traced to a rented cloud server (not bank infrastructure)

➤ **Red flags:**

- Authentication failed: SPF tempered, DKIM none (message not signed), DMARC tempererror — no valid proof the email came from Bradesco
- Real originating server was a generic cloud VM ("ubuntu-s-1vcpu-1gb-35gb-intel-sfo3-06"), not any kind of banking infrastructure
- Subject line uses urgency and reward framing: "Your card has 92,990 Livel points expiring today!"
- The "verify/claim" link in the email body pointed to blog1seguimentmydomaine2bra.me — a throwaway domain with no connection to Bradesco or Livel

➤ **Classification:**

Phishing (bank/loyalty-program impersonation)

7.Email: sample-1013.eml

- **Claims to be from:** shore@suksapan.or.th (a .or.th domain, suggesting a Thai organization) — sender named "Elizabeth Ray"
- **Actually sent from:** The same compromised Thai mail server (host4.ns.co.th) also used in sample-1012, indicating one operation running multiple scam campaigns from shared infrastructure
- **Red flags:**
 - Reply-To mismatch: replies go to elizabethray993@gmail.com, a free Gmail account entirely unrelated to the sending domain
 - Authentication failed: SPF softfail, DKIM none, DMARC none
 - Classic advance-fee/inheritance scam narrative: claims to represent a deceased husband's estate, uses a fabricated cancer diagnosis for emotional urgency, and asks the recipient to "reply for more details" — a setup designed to build trust before requesting money or personal information
 - Generic, non-personalized greeting ("Hi"), sent in bulk
- **Classification:**
 - Phishing (advance-fee / inheritance scam)

#4.Do's and Don'ts List

Do's: -

- Check the sender's actual email address, not just the display name — "Costco Customer Support" can hide any address behind it.
- Hover over links before clicking to see the real destination, and compare it to the organization's official domain.
- Verify unexpected offers, rewards, or account alerts by going directly to the official website or app — never through a link in the email itself.
- Be suspicious of any email creating urgency ("act now," "expires today," "your account will be locked") — this is a deliberate pressure tactic, not a normal business practice.
- Report suspicious emails to your organization's IT or security team rather than just deleting them, so others can be warned.

Don'ts:

- Don't click links or download attachments from unexpected emails, even if they appear to be from a known brand.
- Don't assume an email is safe just because it passed spam filtering and landed in your inbox filters are not perfect.
- Don't assume authentication checks passing (SPF/DKIM/DMARC) guarantees safety — a compromised legitimate mail server can still pass these checks while sending malicious content, as seen in this report's Tether Gold airdrop example.
- Don't reply to unsolicited offers, loan proposals, or inheritance- style requests, even out of curiosity — replying confirms your address is active and invites further targeting.
- Don't let emotional appeals (urgency, sympathy, excitement about a prize) override normal caution — these are the primary tools attackers use to bypass critical thinking.

#5. Conclusion

Across the seven phishing email samples analyzed, several consistent patterns emerged. All seven failed at least one core email authentication check (SPF, DKIM, or DMARC), and in six of seven cases, the sender's claimed identity — a bank, retailer, or well-known brand — had no genuine connection to the domain that actually sent the message. Every sample relied on some form of emotional manipulation, most commonly urgency ("expires today," "verify immediately") or the promise of unexpected reward (prizes, loyalty points, cryptocurrency airdrops).

Notably, one sample (the Tether Gold airdrop scam) demonstrated that authentication checks passing is not, on its own, sufficient proof of safety — the email was sent through a legitimate but compromised mail server, underscoring that technical verification should be one signal among several, not the only one relied upon.

All seven samples were classified as Phishing; none met the threshold for Safe or Suspicious, reflecting that the sample set was drawn from a dedicated phishing archive rather than general inbox traffic.

The patterns identified in this report — sender/domain mismatches, authentication failures, urgency-based language, and disguised or unrelated links — are consistent, learnable indicators. With basic awareness training, most users can be equipped to recognize and avoid the large majority of phishing attempts without needing technical security expertise.